

Міжнародний університет інформаційних технологій
Факультет комп'ютерних технологій та кібербезпеки · Кафедра кібербезпеки

EGR6301 — Етичний хакінг

Підсумковий практичний іспит

Сценарний практичний іспит без виходу на живі системи.

Ви аналізуєте артефакти, які вже зібрав консультант. Ви приймаєте рішення.

Тривалість	100 хвилин
Максимальний бал	100 балів
Кількість задач	9 задач
Формат	Письмова робота на основі наданих артефактів
Дозволено	Конспекти, лекційні матеріали, GTFOBins (друкований)
Заборонено	Доступ до Інтернету, живі VM, чужі звіти, генеративний ШІ
Дата	Весна 2026
Викладач	Тетяна Василівна Бабенко, д.т.н., проф.

Інструкції

Цей іспит перевіряє не вашу пам'ять на команди, а вашу здатність мислити як етичний хакер. Команди ви можете відкрити у GTF0Bins або у власному конспекті. Чого ні в конспекті, ні у пошуку не знайти, це обґрунтування ваших рішень, пріоритезацію векторів атаки, розуміння того, що артефакт вам дає, а чого не дає, і тверезу оцінку ризику для конкретного клієнта. Саме це я й перевірятиму.

Ви отримуєте сценарний бриф уявного інженеру і набір артефактів, які умовний консультант уже зібрав. Жодних живих систем, жодного CTF у реальному часі. Ваше завдання прочитати ці артефакти і на їх основі відповісти на дев'ять запитань.

Як читати завдання

Кожна задача поставлена як питання, на яке немає одного правильного слова чи однієї правильної команди. Я хочу побачити ваші міркування. Якщо ваше рішення відрізняється від мого, але обґрунтоване, ви отримуєте повний бал. Якщо ваше рішення збігається з моїм, але ви не можете пояснити, чому, ви отримуєте половину.

Під кожною задачею стоїть рамка "Що оцінюється". Вона показує, на що я маю звертати увагу. Це не контрольний список, який треба механічно проставити. Це орієнтир, щоб ви не пропустили важливе.

Як писати відповіді

- Пишіть прозою. Не списками з одного слова. Я повинна побачити логіку, а не теги.
- Посилайтеся на конкретні рядки артефактів. Не «Nmap показав вразливість», а «Рядок 4 Артефакту B: vsftpd 2.3.4».
- Команди вписуйте тільки коли задача їх явно просить. У більшості задач команда без пояснення не дасть балів.
- Можна писати від першої особи. «Я обираю...», «Я не довіряю цьому артефакту тому що...»

Часова стратегія

Бюджет часу для кожної задачі зазначено в її заголовку. Не сидіть над однією задачею довше ніж на 50 відсотків понад її бюджет. Краще написати скромну відповідь на всі вісім задач, ніж блискучу на чотири, а решту залишити порожніми.

Перші десять хвилин я раджу витратити на читання всього сценарію і всіх артефактів повністю, без спроби щось розв'язати. Багато задач посилаються на ті самі артефакти з різних кутів, тому загальна картина важливіша за швидкий старт.

Правила оцінювання, що впливають на ваш бал

Калібрування перевірки на типові помилки, які роблять студенти, коли намагаються відповісти, не міркуючи самостійно. Чотири правила нижче діють для всіх 9 задач. Прочитайте їх до початку роботи, а не наприкінці, коли вже не буде часу переписувати.

Правило 1. Посилання на конкретний артефакт. Кожне твердження у вашій відповіді має посилатися на конкретний рядок Артефакту A, B, C, D, E, F або G. Формат посилання: «Артефакт

В, рядок 4: vsftpd 2.3.4». Без таких посилань відповідь на відповідну підзадачу отримує максимум 50% можливих балів, незалежно від того, наскільки переконливо вона написана.

Правило 2. Прив'язка до сценарію. Загальна консультантська проза, яка звучить правильно, але могла бути написана для будь-якого пентесту і не використовує конкретику цього сценарію (клієнт Cassandra Pay, сервер cp-stg-04, IP 192.168.56.108, користувач helios, дата 14 травня 2026), отримує не більше половини балів. Безіменна теорія дешева. Я перевіряю вашу здатність застосувати її до цього клієнта.

Правило 3. Явні припущення. У Задачі 5 і Задачі 8 ви зобов'язані позначати ваші припущення тегом «Припускаю, що...». Без явних припущень з цим тегом відповідні підзадачі отримують максимум 50% балів. У решті задач явні припущення вітаються, але не вимагаються.

Правило 4. Останнє речення кожної задачі. Завершуйте відповідь на кожну задачу (1, 2, 3, 4, 5, 6, 7, 9) реченням, що починається «Я зміню це рішення, якщо...» і містить конкретний тригер. Загальне «якщо ситуація зміниться» не зараховується. Тригер має бути таким, що його можна або побачити у новому артефакті, або почути від клієнта, або зафіксувати у спостереженні. Задача 8 цього не вимагає, бо вона і є про самокорекцію. Відсутність речення знижує бал за задачу на 20%.

Окрема позиція: ваші відповіді на дев'ять задач читаються разом, а не окремо. Якщо у Задачі 3 ви наполягаєте на негайній зупинці робіт через підозру на production, а у Задачі 9 пропонуєте «спочатку перевірити AWS-ключі», це не дві окремі відповіді з різними балами. Це одна суперечність, яка коштує балів на обох задачах. Будьте послідовні. Якщо ви свідомо змінюєте позицію, поясніть, чому змінився контекст.

Сценарій інженементу

Клієнт: Cassandra Pay (фінтех, обробка платежів)

Ціль: сервер cp-stg-04 (192.168.56.108) у staging-сегменті

Тип: гібридний engagement (external recon + assumed-breach після фази розвідки)

Часове вікно: вісім годин, один робочий день, 14 травня 2026 року, 09:00–17:00 за місцевим часом

Винятки зі скоупу: kernel-експлойти, pivot у production-сегмент, ексфільтрація даних, denial-of-service, social engineering співробітників

Спеціальний пункт ROE: якщо під час тестування ви знайдете дані або облікові записи, що можуть стосуватися production-середовища, ви негайно зупиняєте роботу та телефонуєте CISO Оксані Коваленко за номером +7 700 555 0142, щоб отримати письмовий дозвіл. Самостійне просування у production у будь-якій формі є грубим порушенням контракту.

Cassandra Pay звернулася до вашої консультаційної компанії після інциденту у партнерській організації, де staging-сервер виявився плацдармом для атаки на production. Керівництво хоче знати, чи їхня власна staging-інфраструктура має подібні слабкості. Ви, як консультант, не маєте попередніх знань про цю машину. Уся ваша інформація обмежена тим, що ви побачите в артефактах.

Перші дві години інженементу ви провели у фазі розвідки ззовні. Це артефакти B та C. Потім, відповідно до контракту, клієнт надав вам обліковий запис непривілейованого користувача Helios з паролем, відомим з фази розвідки. Це Артефакти D, E, F, G. Усе, що ви бачите, є точним відтворенням того, що з'явилося на екрані під час реальних дій консультанта.

Артефакти

Сім блоків нижче: це повний набір даних, з якого ви будете будувати свої міркування у задачах. Артефакти подані у тому порядку, у якому консультант їх отримував. Жодного артефакту, окрім того, що ви бачите тут, у задачах не передбачено.

Артефакт А — фрагмент ROE-документа

ROE FRAGMENT – Cassandra Pay engagement #CP-2026-014

Section 4.2 Scope of Authorised Activities:

The consultant is authorised to perform reconnaissance, vulnerability identification, and exploitation against the staging server cp-stg-04 and related infrastructure within the 192.168.56.0/24 subnet for the purposes of demonstrating exploitable attack paths.

Section 4.3 Out of Scope:

The following are explicitly prohibited regardless of technical feasibility:

- (a) kernel-level exploitation against any target
- (b) lateral movement into the production VLAN (10.0.0.0/24)
- (c) data exfiltration of customer records or financial data
- (d) denial-of-service or destructive operations
- (e) social engineering of Cassandra Pay employees

Section 4.4 Discovery Stop Clause:

If at any point during testing, the consultant discovers credentials, tokens, or configuration data which reference production systems, testing MUST halt, and the consultant MUST contact the Cassandra Pay CISO at the listed number for written authorisation BEFORE any further action involving those credentials or the production environment.

Артефакт В — результат розвідки портів

```
$ nmap -sV -sC -p- 192.168.56.108
Starting Nmap 7.94 ( https://nmap.org )

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 7.4p1 Debian 10+deb9u6 (protocol 2.0)
25/tcp    open  smtp         Postfix smtpd
| smtp-commands: cp-stg-04, PIPELINING, SIZE 10240000, VRFY,
|_ ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
80/tcp    open  http         Apache httpd 2.4.25 ((Debian))
|_ http-title: Cassandra Pay Staging Portal – under maintenance
139/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn  Samba smbd 4.5.16-Debian (workgroup: WORKGROUP)
3306/tcp   open  mysql        MySQL 5.7.42-1+deb9u1
|_ mysql-info: not authorized to query
6667/tcp   open  irc          UnrealIRCd
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 4.5.16-Debian)
|   Computer name: cp-stg-04
|_  Domain name:

Nmap done: 1 IP address (1 host up) scanned in 142.31 seconds
```

Артефакт С — анонімний доступ до SMB

```
$ smbclient -L //192.168.56.108 -N
Anonymous login successful
```

Sharename	Type	Comment
-----	----	-----
print\$	Disk	Printer Drivers
backups	Disk	Old backup notes – to be archived
IPC\$	IPC	IPC Service (cp-stg-04)

```
$ smbclient //192.168.56.108/backups -N
smb: \> ls
```

.	D	0	Mon May 11 16:22:08 2026
..	D	0	Mon May 11 16:00:01 2026
cleanup_notes.txt	N	584	Mon May 11 16:22:08 2026
smtp_test.eml	N	318	Fri May 8 14:01:33 2026

```
smb: \> get cleanup_notes.txt
```

```
$ cat cleanup_notes.txt
```

```
# Internal notes – do not commit to git
```

```
# Author: helios (devops contractor, leaving end of May)
```

1. /opt/cleanup_helper rotates the apache logs nightly via cron.
It runs as root (suid). Check it before I leave so no one breaks it.
2. The mysql 'staging' user has the SAME password as the production 'reports' user. I know I know. They asked. Creds in /home/helios/.my.cnf when you need them.
3. SSH password for me is the same as the dictionary file I left in the apache directory back in February. epidioko / qwerty / baseball. Pick one, it will work. Yes I know.
4. If you cannot login as helios, ping me. I do not care if it is 2 AM.

Артефакт D — результат Hydra проти SSH

```
$ hydra -l helios -P /tmp/wordlist.txt -t 4 -f ssh://192.168.56.108
Hydra v9.6 (c) 2024 by van Hauser/THC & David Maciejak.
```

```
[DATA] max 4 tasks per 1 server, overall 4 tasks, 3 login tries
[DATA] attacking ssh://192.168.56.108:22/
[22][ssh] host: 192.168.56.108 login: helios password: epidioko
[STATUS] attack finished for 192.168.56.108 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished
```

Артефакт E — файл hashes.txt, знайдений у /home/helios/

```
$ cat /home/helios/old_audit/hashes.txt
```

```
# from staging DB dump 2025-Q3 – keep for password policy comparison
```

```
alice:5f4dcc3b5aa765d61d8327deb882cf99
```

```
bob:daaad6e5604e8e17bd9f108d91e26afe6281dac8fda0091040a7a6d7bd9b43b5
```

```
carol:$argon2id$v=19$m=65536,t=3,p=2$RGiHETV2ejm1qRFXSyBIkg$H/jSLT8bEHRVsQHaG5zajLrZ/9Y1P++LPkexFmUIIdnc
```

```
$ john --test --format=raw-md5 2>&1 | tail -2
```

```
Many salts: 34748K c/s real, 34748K c/s virtual
```

```
Only one salt: 34748K c/s real, 34748K c/s virtual
```

```
$ john --test --format=raw-sha256 2>&1 | tail -2
Many salts:      12876K c/s real, 12876K c/s virtual
Only one salt:   12876K c/s real, 12876K c/s virtual
```

```
$ john --test --format=argon2 2>&1 | tail -2
Speed for cost 1 (t) of 3, cost 2 (m) of 65536
Raw:      2.41 c/s real, 2.41 c/s virtual
```

Артефакт F — SUID-поверхня та sudo -l для helios

```
$ find / -perm -4000 -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/umount
/usr/bin/at
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/sudo
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/opt/cleanup_helper

$ ls -la /opt/cleanup_helper
-rwsr-xr-x 1 root root 8624 Apr 12 09:14 /opt/cleanup_helper

$ sudo -l
[sudo] password for helios:
Matching Defaults entries for helios on cp-stg-04:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User helios may run the following commands on cp-stg-04:
    (ALL : ALL) NOPASSWD: /usr/bin/find
```

Артефакт G — статичний аналіз /opt/cleanup_helper

Зверніть увагу на те, що рядки команд виглядають точно так, як вони передаються у system().

```
$ file /opt/cleanup_helper
/opt/cleanup_helper: ELF 64-bit LSB executable, x86-64, dynamically
linked (uses shared libs), for GNU/Linux 3.2.0, stripped

$ strings /opt/cleanup_helper | grep -vE '^[[:space:]]*$' | head -25
/lib64/ld-linux-x86-64.so.2
libc.so.6
setuid
system
exit
__libc_start_main
cleanup_helper v1.2 (build 2025-09-30)
rotating apache logs in /var/log/apache2
rm -f /var/log/apache2/access.log.5
mv /var/log/apache2/access.log.4 /var/log/apache2/access.log.5
mv /var/log/apache2/access.log.3 /var/log/apache2/access.log.4
mv /var/log/apache2/access.log.2 /var/log/apache2/access.log.3
```

```
mv /var/log/apache2/access.log.1 /var/log/apache2/access.log.2
gzip /var/log/apache2/access.log
logger -t cleanup_helper rotation complete
GCC: (Debian 6.3.0-18+deb9u1) 6.3.0 20170516
```

Завдання

Дев'ять задач нижче пов'язані одним сценарієм, але кожна перевіряє свій бік мислення. Деякі задачі вимагають, щоб ви заперечили очевидне рішення. Це не пастка. Це справжня робота консультанта.

Задача 1. Чи можна взагалі починати (8 балів · ~12 хв)

Перечитайте Артефакт А. Уявіть, що ви консультант, який щойно його підписав. До початку реальної роботи ви маєте 30 хвилин на брифінг із вашою командою.

Дайте відповідь на три питання у формі короткого внутрішнього меморандуму обсягом 200–300 слів.

- (а) У пункті 4.2 ROE є фраза «and related infrastructure within the 192.168.56.0/24 subnet». Що саме у ній вас бентежить як консультанта і чому ви хочете уточнити її до старту, а не під час роботи?
- (б) Який юридичний документ Республіки Казахстан застосовуватиметься до ваших дій у разі помилки? Назвіть конкретну статтю і поясніть, чому саме вона, а не загальне посилання на «закон».
- (в) Sections 4.4 (Discovery Stop Clause) є для вас захистом чи обмеженням? Поясніть, що ви насправді отримуєте від цього пункту як консультант, окрім очевидного.

Завершіть задачу реченням «Я зміню це рішення, якщо...» з конкретним тригером.

Що оцінюється

- Чи побачили ви насправді неоднозначність у 4.2, а не «все ясно»
- Чи названо конкретну статтю КК РК і чи пояснено вибір саме її
- Чи усвідомлюється Discovery Stop Clause як двосторонній механізм
- Чи звучить це як меморандум професіонала, а не переказ лекції

Задача 2. Який сервіс ви атакуєте першим і чому (12 балів · ~14 хв)

Подивіться на Артефакт В. У вас вісім відкритих портів, і кілька з них мають відомі вразливості. Ви маєте 90 хвилин на фазу зовнішньої експлуатації.

Складіть ваш робочий план у форматі впорядкованого списку з 3 пунктів.

- (а) Який сервіс ви атакуєте першим? Не «vsftpd має бекдор», а чому саме він першим, а не другим. Тут грає роль час до першого результату, надійність експлойта, і ваша оцінка того, наскільки публічна інформація про цей CVE.
- (б) Який сервіс ви атакуєте другим? Поясніть, чому саме у такому порядку. Якщо ваш другий вибір залежить від результату першого, скажіть це явно.
- (в) Один зі сервісів у списку, найімовірніше, є хибним слідом, тобто навмисною приманкою або просто непродуктивним вектором при цьому конкретному часовому бюджеті. Який саме і чому? Тут я очікую почути не «UnrealIRCd небезпечний», а пояснення, чому навіть якщо він небезпечний, у вашій ситуації йти у нього перш ніж у решту, це професійна помилка.

Завершіть задачу реченням «Я зміню це рішення, якщо...» з конкретним тригером.

Що оцінюється

- Чи відрізняється «що атакувати» від «у якому порядку»

- Чи звертається аргументація до часу, надійності, та публічності експлойта, а не лише до CVSS
- Чи названо конкретний хибний слід із розгорнутим обґрунтуванням
- Чи помітно, що ви розрізняєте «можна» і «варто»

Задача 3. Що з цим робити (10 балів · ≈10 хв)

Артефакт C містить файл `cleanup_notes.txt`. Прочитайте його уважно і дайте відповідь на три пов'язані питання.

(а) Пункт 2 нотаток повідомляє вам, що `staging mysql user` має той самий пароль, що і `production reports user`. Це знахідка, яка лежить просто на поверхні. Що ви робите з нею у наступні п'ять хвилин? Конкретно, тобто хто з ким говорить, у якому порядку, і що пишеться у журналі `engagement`.

(б) Пункт 1 натякає на привілейований бінарник `/opt/cleanup_helper`. Що саме в нотатках каже, що цей слід пріоритетний, а що — що він може бути спеціально залишеною приманкою? Не «треба перевірити», а які саме ознаки з тексту нотаток грають роль приманки, а які: роль проти.

(в) Який сигнал на стороні Blue Team мав би згенеруватися через те, що ви щойно зробили з цим файлом? Назвіть подію, яку б ви, як захисник Cassandra Ray, шукали в логах SMB-сервера. Не «треба моніторити SMB», а конкретну подію.

Завершіть задачу реченням «Я зміню це рішення, якщо...» з конкретним тригером.

Що оцінюється

- Чи названо конкретний алгоритм дій з Discovery Stop Clause у відповіді (а)
- Чи аналіз пункту (б) розрізняє свідчення «за пастку» і свідчення «проти»
- Чи виявлено зміну перспективи на захисника у пункті (в)
- Чи не звужено відповідь до «треба все перевірити»

Задача 4. Невдача та що тепер (10 балів · ≈10 хв)

Артефакт D показує успіх Hydra. Тепер уявіть альтернативну реальність. Той самий запуск повернувся через 23 секунди з повідомленням:

альтернативний сценарій

```
[ERROR] could not connect to ssh://192.168.56.108:22 - kex_exchange_identification: Connection
closed by remote host
1 of 1 target completed, 0 valid passwords found
```

Жодна валідна пара не знайдена. Атака начебто не запустилася взагалі.

(а) Назвіть три різні правдоподібні причини того, що Hydra не змогла встановити з'єднання. Не «сервер недоступний», а саме чому з'єднання обірвалося до того, як інструмент встиг спробувати облікові дані. Розташуйте їх від найімовірнішого до найменш імовірного у цьому контексті.

(б) Для найімовірнішої причини опишіть конкретну наступну дію, яка перевірить вашу гіпотезу. Якщо ця дія дасть очікуваний результат, що ви робитимете далі? Якщо вона не дасть, до якої з решти двох гіпотез ви повернетесь?

(в) Чи маєте ви право в цій ситуації змінювати конфігурацію свого Kali, щоб обійти проблему? Поясніть, де закінчується законна адаптація і де починається штучне зниження безпеки. Зверніть увагу на формулювання Section 4.3 ROE.

Завершіть задачу реченням **«Я зміню це рішення, якщо...»** з конкретним тригером.

Що оцінюється

- Чи три гіпотези справді різні, а не варіації однієї
- Чи план дій розгалужений залежно від результату першої перевірки
- Чи усвідомлюється, що зниження безпеки на боці консультанта це не безкоштовно
- Чи це звучить як живе мислення, а не імпровізована теорія

Задача 5. Хеші і чесна оцінка часу (12 балів · ≈10 хв)

Артефакт E показує три хеші з різних алгоритмів і бенчмарки John the Ripper на робочій станції консультанта. Wordlist rockyou.txt містить приблизно 14 мільйонів паролів.

(а) Для кожного з трьох хешів дайте реалістичну оцінку часу знаходження пароля в словнику rockyou.txt за умови, що пароль дійсно в ньому є. Просто "швидко" або "довго" не зараховується. Я хочу побачити арифметику із цифрами з артефакту, з оцінкою порядку величини, і з явним зазначенням припущення, де ви припускаєте, а де знаєте.

(б) У вас на повну фазу офлайн-крекінгу виділено сорок хвилин. Який з трьох хешів ви запускаєте першим, який другим, який третім або не запускаєте взагалі? Захищайте порядок.

(в) Чи професійно намагатися дешифрувати Argon2id за відведених сорок хвилин, знаючи, що з найвищою ймовірністю ви нічого не отримаєте? Я не питаю, чи це технічно можливо. Я питаю, чи це професійно. Аргументуйте з огляду на те, що клієнт платить вам за результат, не за процес.

Нагадування: ця задача вимагає явних тегів «Припускаю, що...» біля кожного припущення (Правило 3 з Інструкцій). Якщо ви припускаєте, що пароль є у rockyou.txt, скажіть це. Якщо ви припускаєте, що швидкість John лінійно екстраполюється на більшу wordlist, скажіть це теж.

Завершіть задачу реченням **«Я зміню це рішення, якщо...»** з конкретним тригером.

Що оцінюється

- Чи є явна арифметика з цифрами з Артефакту E у пункті (а)
- Чи розрізняє студент відмінність між «не зломлю» і «спробую і запишу»
- Чи відповідь у (в) виходить за межі бінарного «так/ні» у формат професійного судження
- Чи названо хоча б одне припущення явно, з тегом «припускаю, що...»

Задача 6. Чим ви насправді володієте на цій машині (16 балів · ≈15 хв)

Подивіться на Артефакти F та G разом. У вас є два потенційні вектори ескалації привілеїв, і вони відрізняються за характером.

(а) Опишіть обидва вектори в термінах «що адміністратор зробив не так». Не «там SUID на find», а в чому саме архітектурна помилка кожного з них. Це має бути два різні речення про дві різні помилки, навіть якщо обидва вектори дають вам root.

(б) Який із двох векторів ви використовуєте першим і чому? Тут грає роль не лише надійність, а й те, що один з них залишає глибший слід у логах. Поясніть, що це означає для вашого engagement, якщо клієнт згодом захоче розслідувати ваші дії.

(в) Уявіть, що ви тепер на боці Blue Team Cassandra Pay. Який мінімальний набір правил auditd, на вашу думку, виявив би атаку через ту саму поверхню, але без false positives? Тут я очікую почути не повний синтаксис правил, а аргумент: який системний виклик найточніше відрізняє злом від нормальної роботи sysadmin.

(г) Якби клієнт сказав вам: «У нас не вистачає бюджету на технічний фікс прямо зараз. Запропонуйте процесну зміну, яка зменшить цей ризик до прийнятного рівня.» Що б ви відповіли? Лише процесна: без покупок, без змін у коді.

Завершіть задачу реченням «Я зміню це рішення, якщо...» з конкретним тригером.

Що оцінюється

- Чи дві помилки конфігурації справді різні за природою у пункті (а)
- Чи розглянуто слід в логах як критерій вибору у (б)
- Чи у (в) обґрунтовано конкретний syscall, а не загальне «треба моніторити exesvc»
- Чи процесна порада у (г) реалістична і не маскує брак технічної компетенції

Задача 7. Severity для цього клієнта (12 балів · ≈14 хв)

Уявіть, що ви пишете технічну знахідку для звіту, який піде до CISO Cassandra Pay. Знахідка одна, ваш вибір: SUID на /opt/cleanup_helper або правило sudo NOPASSWD: /usr/bin/find.

Інший консультант із вашої команди заздалегідь оцінив цю знахідку як Critical (CVSS 9.8). Ви маєте з ним посперечатися перед фінальним релізом звіту.

(а) Чому 9.8 у цьому контексті може бути неправильно? Тут я очікую не атаку на CVSS як метод, а конкретно: який компонент вектора, ймовірно, завищений у нього і чому. Якщо ви вважаєте, що 9.8 насправді правильне, скажіть це і захищайте.

(б) Запропонуйте власну severity з вектором CVSS v3.1 і поясніть кожен компонент вектора в короткому реченні. AV, AC, PR, UI, S, C, I, A.

(в) Напишіть рекомендацію клієнту у двох реченнях. Не «зніміть SUID», а адресна, кількісно вимірна рекомендація з посиланням на стандарт. Друге речення має чесно говорити, скільки часу або людино-годин це коштуватиме.

Завершіть задачу реченням «Я зміню це рішення, якщо...» з конкретним тригером.

Що оцінюється

- Чи аргумент про severity спирається на конкретний компонент вектора
- Чи новий вектор пояснений покомпонентно, а не одним числом
- Чи рекомендація містить і дію, і ціну її впровадження
- Чи тон звучить як до CISO, а не як до однокурсника

Задача 8. Що ви припускали (10 балів · ≈12 хв)

Подивіться на свої власні відповіді у задачах 1 — 7. Уся ваша робота тримається на наборі припущень, які ви, можливо, навіть не помітили.

(а) Назвіть три припущення, які ви зробили в попередніх задачах і які могли б виявитися неправильними. Не «можливо я помилився», а конкретні припущення з обов'язковим тегом «Припускаю, що...» (Правило 3 з Інструкцій). Краще, якщо ці припущення будуть з різних задач.

(б) Для кожного з трьох припущень опишіть конкретну подію або артефакт, який змусив би вас змінити думку. Тобто, що мало б статися або що мало б з'явитися у наступному запуску інструменту, щоб ви визнали припущення хибним.

(в) Із цих трьох припущень оберіть одне, яке у разі помилковості найбільше зашкодить engagement. Не вашій оцінці на іспиті. Реальному клієнту. Захищайте вибір.

Що оцінюється

- Чи припущення справді з вашої роботи, а не загальні «можна було помилитися»
- Чи кожне має конкретний тригер зміни думки
- Чи у (в) визначено вплив на клієнта, а не на бал
- Чи відчутна метакогніція, тобто чи студент справді подумав про власне мислення

Задача 9. AWS-кредентіали з натяком на production (10 балів · ≈12 хв)

Через двадцять хвилин після експлуатації SUID-вектора, далі обстежуючи домашню директорію helios, ви знаходите файл /home/helios/.aws/credentials з таким вмістом:

```
[default]
aws_access_key_id = AKIA*****
aws_secret_access_key = *****
region = eu-central-1
```

Одночасно у bash history того ж користувача ви бачите:

```
$ history | tail -5
517  ssh admin@10.0.0.14
518  scp backup.sql admin@10.0.0.14:/srv/backups/
519  aws s3 ls s3://cassandra-prod-reports/
520  exit
521  history | tail -5
```

Нагадую дві позиції ROE з Артефакту A: production VLAN 10.0.0.0/24 явно виключена зі скоупу, а Discovery Stop Clause застосовується до credentials або configuration data, що посилаються на production systems.

Напишіть incident мемо обсягом 250–400 слів, що містить відповіді на чотири питання. Це не наратив, це робочий документ для CISO, тому пишіть стисло і конкретно.

(а) Чи маєте ви право перевіряти ці AWS credentials, наприклад, виконавши `aws sts get-caller-identity`, щоб з'ясувати, чи це staging чи production? Якщо ні, то як саме ви визначаєте, до якого середовища вони належать, не використовуючи самі credentials?

(б) Яку саме дію ви робите першою після цієї знахідки? Не «повідомляю менеджера», а конкретна операційна послідовність крок за кроком, у правильному порядку. Назвіть щонайменше п'ять кроків.

(в) Назвіть три конкретні дії, які у цій ситуації вже були б порушенням ROE. Для кожної вкажіть, який саме пункт ROE вона порушує (4.3а–е або 4.4).

(г) Який мінімальний набір доказів ви повинні зафіксувати перед зупинкою робіт? Не повний журнал engagement, а саме той мінімум, без якого CISO не зможе ухвалити рішення. Назвіть, чого ви свідомо НЕ робите під час збору доказів і чому.

Завершіть задачу реченням **«Я зміню це рішення, якщо...»** з конкретним тригером.

Що оцінюється

- Чи розрізняє студент «знайти» і «використати»
- Чи правильно застосовується Discovery Stop Clause у послідовності дій
- Чи студент мислить як consultant under contract, а не як CTF-учасник
- Чи операційна послідовність у (б) реалістична, а не теоретична
- Чи студент не плутає evidence preservation з exploitation у (г)

Кінець іспиту

Перевірте, що ви відповіли на всі дев'ять задач, а не лише на ті, які знаєте найкраще.